API Security Risk Analysis Report

Cyber Security Internship – Task 3

1.Introduction

This report presents the findings of an API Security Risk Analysis conducted on a public test API using Postman. The objective of this assessment was to identify potential security vulnerabilities related to authentication, data exposure, input validation, and rate limiting.

The analysis was performed using the JSONPlaceholder test API to simulate real-world API security risks in a safe environment.

Tools Used

Postman

Public Test API (JSONPlaceholder)

Browser-based testing

Findings & Identified Security Risks

- ✓ Lack of Authentication

The API allowed access to user information without requiring authentication credentials. Any user could retrieve data simply by sending a request.

Impact:
Unauthorized access to sensitive information may occur.

Risk Level: High

Recommendation:
Implement authentication mechanisms such as JWT tokens or API keys.

- ✓ Sensitive Data Exposure

User data including email, phone number, address, and geo-location were accessible without restriction.

Impact:
Exposure of personally identifiable information (PII) may lead to privacy violations or

identity theft.

Risk Level: High

Recommendation:
Limit publicly accessible fields and enforce role-based access control.

- ✓ Absence of Rate Limiting

Repeated requests were processed without any throttling or blocking.

Impact:
Attackers could overwhelm the system through automated requests.

Risk Level: Medium

Recommendation:
Implement request throttling and IP-based rate limiting.

- ✓ Lack of Input Validation

Malicious script input was accepted without filtering.

Impact:
This may allow Cross-Site Scripting (XSS) attacks.

Risk Level: High

Recommendation:
Sanitize inputs and validate request payloads.

Risk Analysis

The identified vulnerabilities may expose systems to:

• Unauthorized access
• Data breaches
• Service disruption
• Malicious code execution

These risks can negatively impact confidentiality, integrity, and availability of systems.

Recommended Security Improvements

To mitigate the identified risks, the following security measures are recommended:

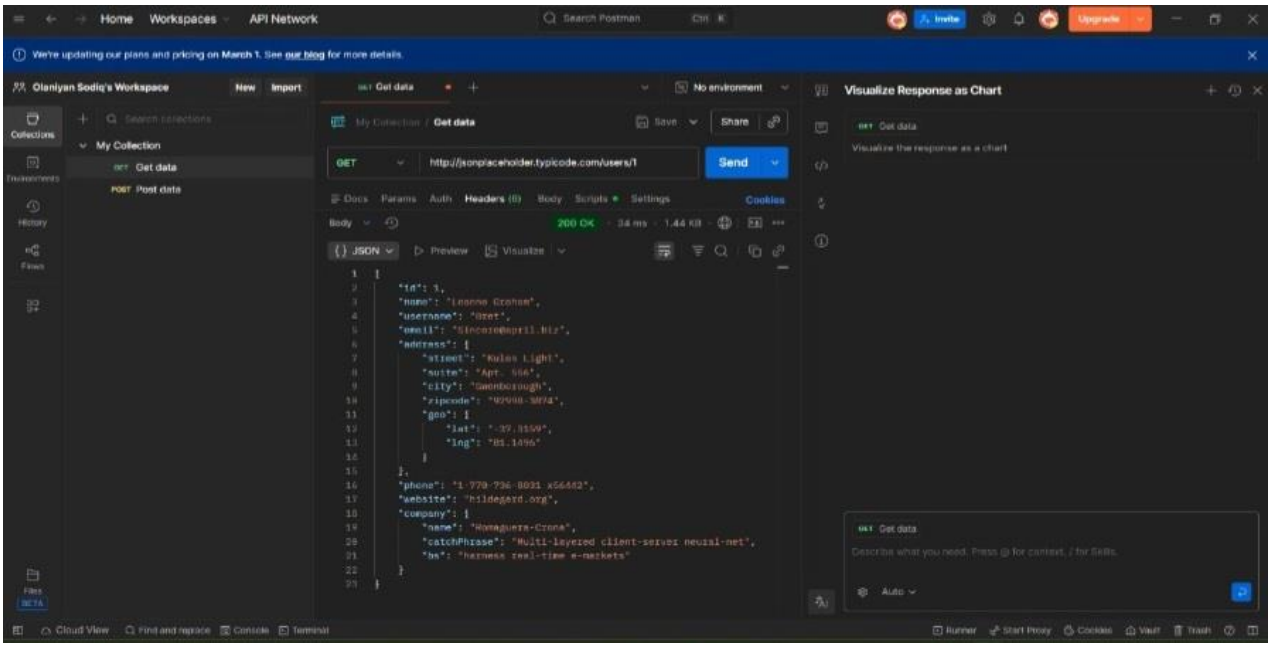
- Implement authentication and authorization controls
- Protect sensitive data
- Apply rate limiting mechanisms
- Validate and sanitize inputs
- Monitor API activity through logging

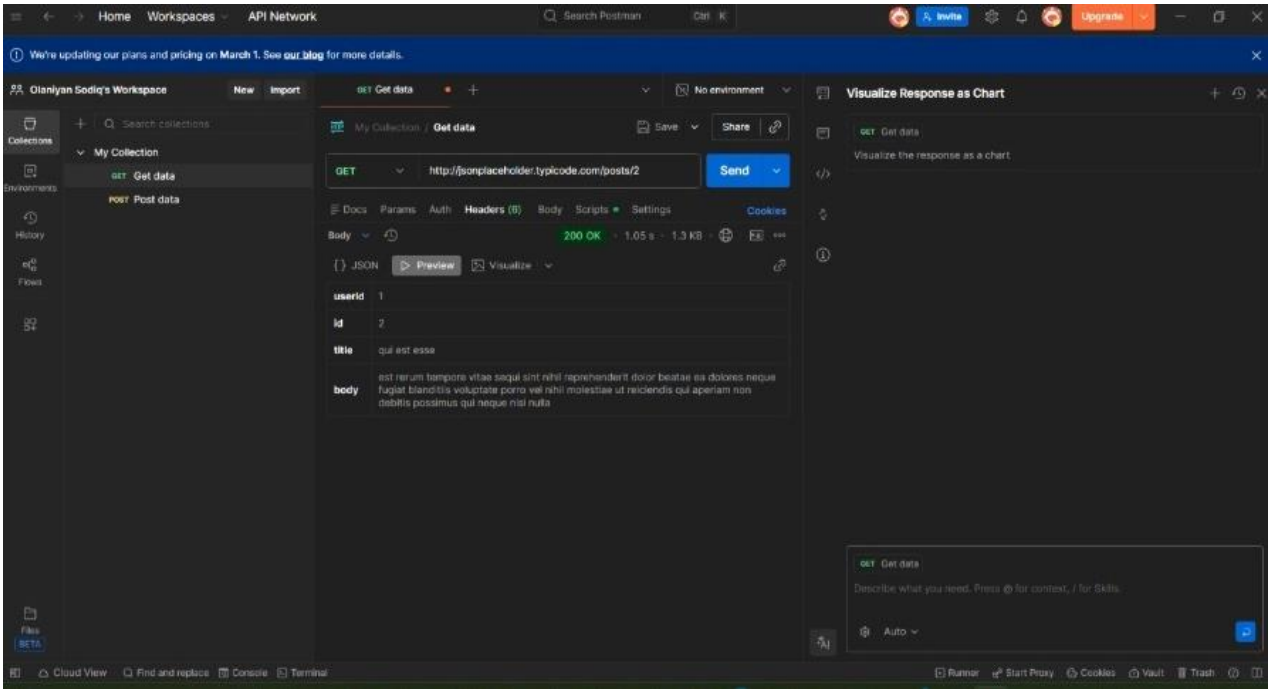
Conclusion

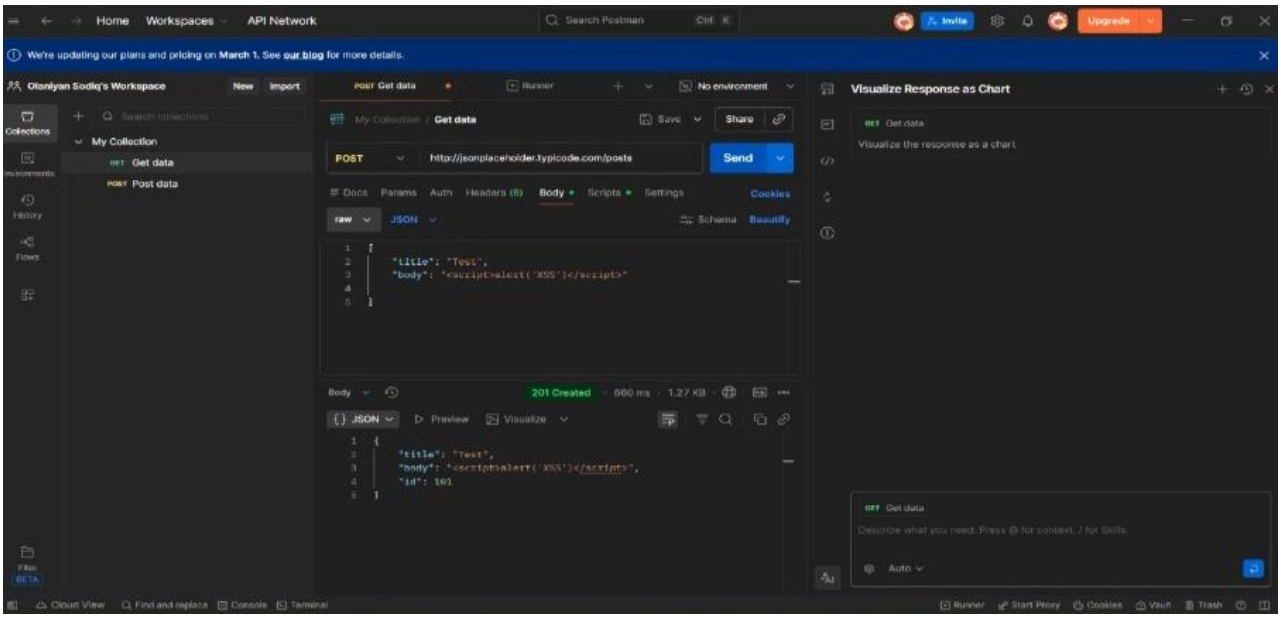
The API security assessment identified several critical vulnerabilities that must be addressed to ensure
secure operation. Proper authentication, input validation, and request limiting are essential to protect systems and users.

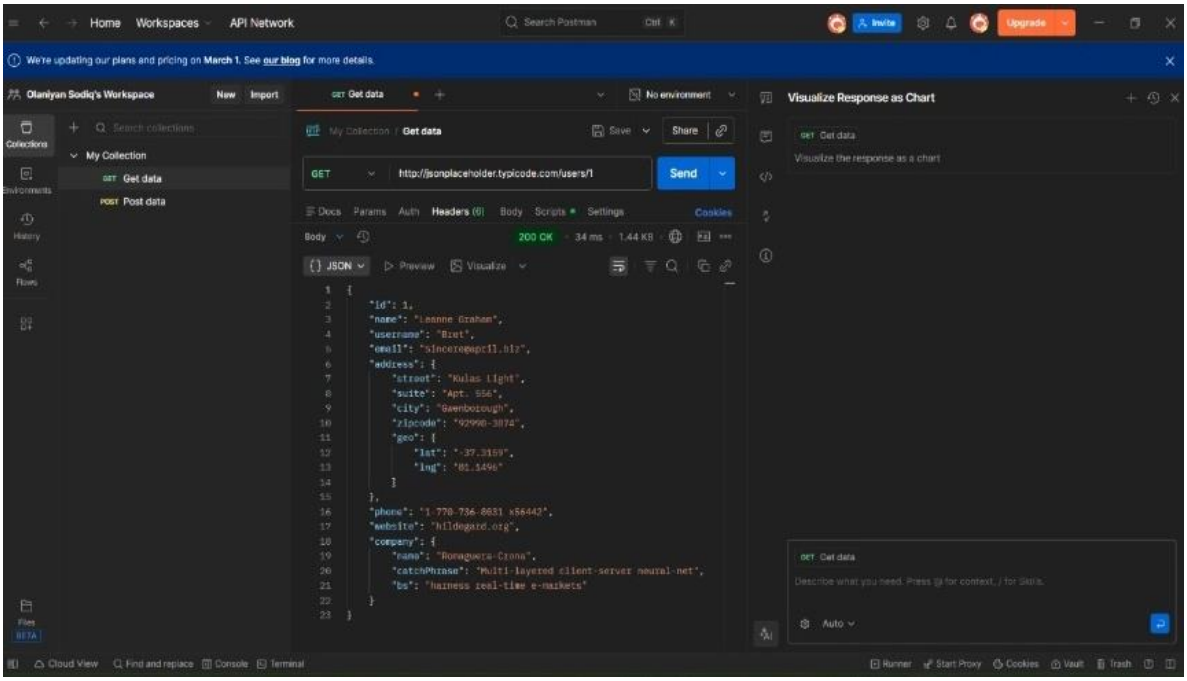
Implementing these controls will significantly improve API security and reduce the likelihood of exploitation.

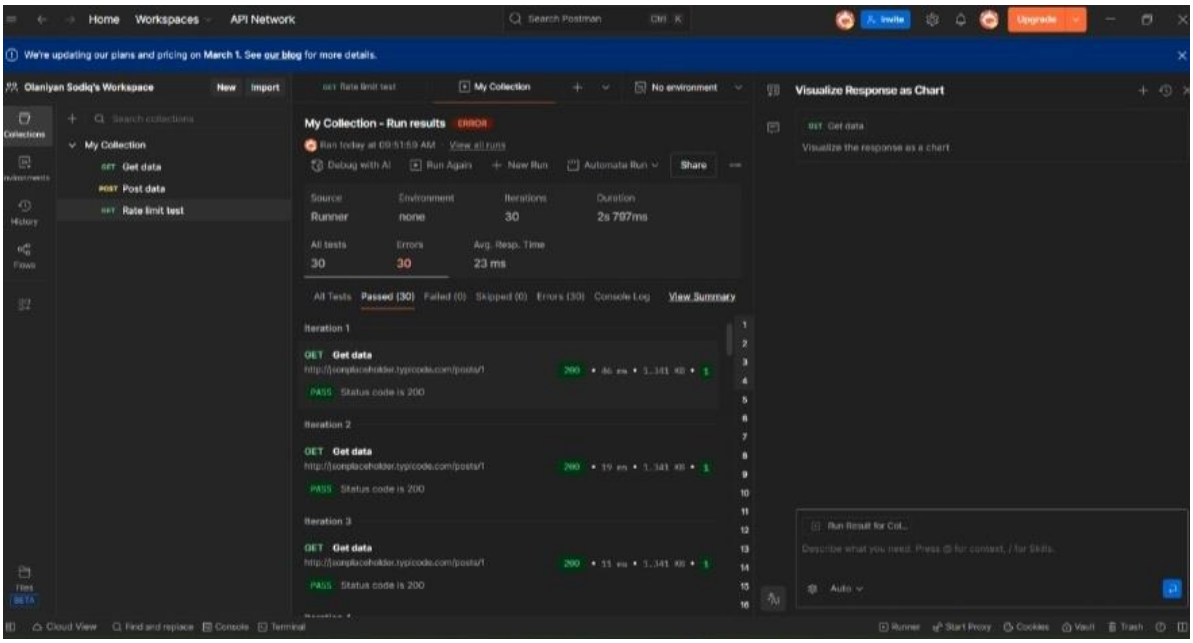
Proof of concept




Home
Workspaces
API Network
Search Postman
Invite
Upgrade
We're updating our plans and pricing on March 1. See our blog for more details.
Olaniyan Sodiq's Workspace
New
Import
Collections
Environments
History
Flows
Files
BETA
My Collection
GET Get data
POST Post data
GET Get data
No environment
My Collection / Get data
Save
Share
GET
http://jsonplaceholder.typicode.com/posts/2
Send
Docs
Params
Auth
Headers (8)
Body
Scripts
Settings
Cookies
Body
200 OK
1.05 s
1.3 KB
JSON
Preview
Visualize
userId 1
id 2
title qui est esse
body est rerum tempore vitae sequi sint nihil reprehenderit dolor beatae ea dolores neque fugiat blanditiis voluptate porro vel nihil molestiae ut reiciendis qui aperiam non debitis possimus qui neque nisi nulla
Visualize Response as Chart
GET Get data
Visualize the response as a chart
GET Get data
Describe what you need. Press @ for context, / for Skills.
Auto
Cloud View
Find and replace
Console
Terminal
Runner
Start Proxy
Cookies
Vault
Trash


Home
Workspaces
API Network
Search Postman
Invite
Upgrade
We're updating our plans and pricing on March 1. See our blog for more details.
Olaniyan Sodiq's Workspace
New
Import
Collections
Environments
History
Flows
Files
BETA
My Collection
GET Get data
POST Post data
POST Get data
Runner
No environment
My Collection / Get data
Save
Share
POST
http://jsonplaceholder.typicode.com/posts
Send
Docs
Params
Auth
Headers (8)
Body
Scripts
Settings
Cookies
raw
JSON
Schema
Beautify
{
"title": "Test",
"body": "<script>alert('XSS')</script>"
}
Body
201 Created
660 ms
1.27 KB
JSON
Preview
Visualize
{
"title": "Test",
"body": "<script>alert('XSS')</script>",
"id": 101
}
Visualize Response as Chart
GET Get data
Visualize the response as a chart
GET Get data
Describe what you need. Press @ for context, / for Skills.
Auto
Cloud View
Find and replace
Console
Terminal
Runner
Start Proxy
Cookies
Vault
Trash


Home
Workspaces
API Network
Search Postman
Invite
Upgrade
We're updating our plans and pricing on March 1. See our blog for more details.
Olaniyan Sodiq's Workspace
New
Import
Collections
Environments
History
Flows
Files
BETA
My Collection
GET Get data
POST Post data
GET Get data
My Collection / Get data
Save
Share
GET
http://jsonplaceholder.typicode.com/users/1
Send
Docs
Params
Auth
Headers (6)
Body
Scripts
Settings
Cookies
Body
200 OK
34 ms
1.44 KB
JSON
Preview
Visualize
{
"id": 1,
"name": "Leanne Graham",
"username": "Bret",
"email": "Sincere@april.biz",
"address": {
"street": "Kulas Light",
"suite": "Apt. 556",
"city": "Gwenborough",
"zipcode": "92998-3874",
"geo": {
"lat": "-37.3159",
"lng": "81.1496"
}
},
"phone": "1-770-736-8031 x56442",
"website": "hildegard.org",
"company": {
"name": "Romaguera-Crona",
"catchPhrase": "Multi-layered client-server neural-net",
"bs": "harness real-time e-markets"
}
}
Visualize Response as Chart
GET Get data
Visualize the response as a chart
GET Get data
Describe what you need. Press @ for context, / for Skills.
Auto
Cloud View
Find and replace
Console
Terminal
Runner
Start Proxy
Cookies
Vault
Trash


Home
Workspaces
API Network
Search Postman
Invite
Upgrade
We're updating our plans and pricing on March 1. See our blog for more details.
Olaniyan Sodiq's Workspace
New
Import
Collections
Environments
History
Flows
Files
BETA
My Collection
GET Get data
POST Post data
GET Rate limit test
GET Rate limit test
My Collection
No environment
My Collection - Run results
ERROR
Run today at 09:51:59 AM
View all runs
Debug with AI
Run Again
New Run
Automate Run
Share
Source
Runner
Environment
none
Iterations
30
Duration
2s 797ms
All tests
30
Errors
30
Avg. Resp. Time
23 ms
All Tests
Passed (30)
Failed (0)
Skipped (0)
Errors (30)
Console Log
View Summary
Iteration 1
GET Get data
http://jsonplaceholder.typicode.com/posts/1
200
PASS Status code is 200
Iteration 2
GET Get data
http://jsonplaceholder.typicode.com/posts/1
200
PASS Status code is 200
Iteration 3
GET Get data
http://jsonplaceholder.typicode.com/posts/1
200
PASS Status code is 200
Visualize Response as Chart
GET Get data
Visualize the response as a chart
Run Result for Col...
Describe what you need. Press @ for context, / for Skills.
Auto
Cloud View
Find and replace
Console
Terminal
Runner
Start Proxy
Cookies
Vault
Trash

Prepared by: Mohamed Dahir Mohamed

Organization: Future interns

Task: Cyber security Task3